

14. Mitigation Strategies

14.1 Introduction

Mitigation Strategies define the corrective actions and best practices required to eliminate or reduce security vulnerabilities identified during security testing. These strategies are essential to improve the overall security posture of the OWASP Juice Shop Web Application and prevent exploitation of common vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), and input validation flaws.

The goal of this section is to provide actionable solutions that can be implemented by developers to secure the application against malicious attacks and ensure safe user interaction.

14.2 SQL Injection Fixes

Introduction

SQL Injection is a critical security vulnerability that occurs when user input is directly included in SQL queries without proper validation or sanitization. Attackers can manipulate queries to access or modify database data.

Mitigation Techniques

1. Use of Prepared Statements (Parameterized Queries)

- Always use parameterized queries instead of dynamic SQL
 - Separates SQL logic from user input
 - Prevents malicious input from altering query structure
-

2. Input Validation

- Validate all user inputs before processing
 - Restrict special characters such as ', ", ;, --
 - Enforce strict data type validation
-

3. Use of ORM Frameworks

- Use frameworks like Hibernate or JPA
 - Automatically handles query sanitization
 - Reduces direct SQL usage
-

4. Least Privilege Database Access

- Database user should have minimal required permissions
 - Prevents full database compromise
-

Outcome

Implementing these measures significantly reduces the risk of SQL Injection attacks and protects sensitive database information.